УЧЕБНОЕ ДЕЛО ML-017

Расследование утечки данных

Дело ML-017: компрометация корпоративной учётной записи

Студенты колледжей и вузов, взрослые участники; рекомендуемый возраст 16+ · 35–45 минут

Ваша задача

Вы — аналитик группы реагирования вымышленной компании «Меридиан». Контроль передачи данных обнаружил отправку клиентского файла во внешнее хранилище. Руководству нужен первичный отчёт: как мог возникнуть инцидент, какой сеанс использован, сколько записей подтверждённо передано и какие действия нужны сейчас. В кабинете пять источников: переписка, журнал входов, карточка выгрузки, план реагирования и проект отчёта. Сопоставляйте доказательства и отделяйте подтверждённые факты от предположений. Все данные вымышлены, время — московское (UTC+3).

Решите пять задач. Формат ответа указан в вопросе. Каждое решение обоснуйте ссылкой на источник.

1. Рабочая гипотеза

Рабочий стол: переписка

> СПРАВКА
> Официальный портал: https://id.meridian.example.
>
> ПИСЬМО, 08:52
> От: it-support@meridian-help.example
> Тема: «Переподключение корпоративного доступа»
> Текст: «Сегодня завершается обновление. Подтвердите доступ на https://login.meridian-help.example/verify и одобрите запрос MFA».
>
> ОБЪЯСНЕНИЕ СОТРУДНИКА U-041
> «В 08:56 я ввёл рабочий пароль на странице из письма. Позже подтвердил запрос MFA. Вход на новом устройстве и экспорт клиентов я самостоятельно не запускал».
>
> ЖУРНАЛ ВХОДОВ
> 09:00:00 | U-041 | S-884 | новое устройство | MFA=approved | result=success
>
> Какую рабочую гипотезу прежде всего следует проверять?
> 1) Сбой CRM самопроизвольно отправил все данные.
> 2) Доказано, что U-041 намеренно продал клиентскую базу.
> 3) Пароль мог быть перехвачен через поддельный портал, а подтверждение MFA использовано для чужого входа.
> 4) Вход точно безопасен: ссылка использует HTTPS, MFA подтверждён.
> Введите номер одного варианта.

2. Связать вход и выгрузку

Монитор: журнал операций

> ЖУРНАЛ ВХОДОВ
> 08:50:00 | S-118 | U-041 | известное устройство | success
> 09:00:00 | S-884 | U-041 | новое устройство | success
> 09:02:00 | S-203 | U-097 | известное устройство | success
> 09:02:30 | S-902 | U-012 | известное устройство | success
>
> АУДИТ CRM
> 08:51:00 | S-118 | просмотр карточек | result=success
> 09:04:00 | S-884 | export_id=E-17 | rows=4820 | result=success
> 09:05:00 | S-203 | попытка экспорта | rows=0 | result=denied
> 09:06:00 | S-902 | export_id=E-19 | rows=1500 | result=success
>
> КАРТОЧКА DLP
> Во внешнее, не согласованное компанией хранилище передан файл E-17. Для E-19 зафиксировано внутреннее согласованное размещение.
>
> Какой сеанс непосредственно связан с успешной выгрузкой E-17?
> Введите только цифровую часть идентификатора, без S- и пробелов.

3. Подтверждённый масштаб

Шкаф с документами: карточка выгрузки

> СПРАВКА
> Всего в CRM — 15 000 клиентских записей.
>
> КАРТОЧКА ВЫГРУЗКИ
> export_id=E-17
> file=clients_E17.csv
> unique_records=4820, заголовок CSV не учитывается
> fields=имя, телефон, адрес электронной почты
> sha256=10963459db9307774b5d3502f9113509664c08b3880f6bdb36989a565b4a8d61
>
> ЗАПИСЬ DLP, 09:07:10
> file=clients_E17.csv
> sha256=10963459db9307774b5d3502f9113509664c08b3880f6bdb36989a565b4a8d61
> destination=external_unapproved
> transfer_status=completed
> whole_file=yes
>
> Файл E-19 с 1 500 записями размещён во внутреннем согласованном хранилище. Журналы других возможных передач пока проверяются.
>
> Каково минимальное подтверждённое количество уникальных клиентских записей, переданных во внешнее несогласованное хранилище?
> Введите число без пробелов и разделителей.

4. Выбрать меры реагирования

Телефон: согласование реагирования

> ОБСТАНОВКА
> Сеанс S-884 ещё действителен. Смена пароля заблокирует новый вход, но уже выданный сеанс автоматически не отзовёт. Причина окончательно не установлена. Журналы CRM и DLP доступны. Признаков заражения всех рабочих станций пока нет.
>
> Выберите наиболее обоснованный план первичных действий.
> 1) Только сменить пароль U-041 и вернуть сотрудника к работе, считая инцидент завершённым.
> 2) Отозвать сеансы и токены U-041, ограничить несогласованное внешнее направление, параллельно сохранить журналы и артефакты; проверить защиту аккаунта и уведомить ответственных по регламенту.
> 3) Удалить U-041 вместе с историей действий и переустановить все компьютеры компании.
> 4) Отложить блокировку до конца рабочего дня, чтобы собрать максимум наблюдений за действующим сеансом.
> Введите номер одного варианта.

5. Факты для первичного отчёта

Папка на столе: проект отчёта

> СВОДКА ДОКАЗАТЕЛЬСТВ
> Аудит: успешная выгрузка E-17 выполнена в сеансе S-884 учётной записи U-041.
> Экспорт: 4 820 уникальных записей, поля — имя, телефон и электронная почта.
> DLP: весь тот же файл с совпадающим хешем передан во внешнее несогласованное хранилище.
> Реагирование: в 09:11 подтверждён отзыв сеансов U-041, в 09:12 — блокировка выявленного внешнего направления.
> Идентификация оператора и остальные передачи ещё проверяются.
>
> Какие утверждения можно включить в «Подтверждённые факты»?
> 1) Подтверждена внешняя передача файла с 4 820 уникальными клиентскими записями.
> 2) Доказано, что U-041 лично продал данные конкурентам.
> 3) Подтверждена утечка номеров банковских карт.
> 4) Для выгрузки E-17 использована учётная запись U-041, сеанс S-884.
> 5) Подтверждена утечка всех 15 000 записей CRM.
> 6) Отзыв сеансов и блокировка направления подтверждены журналом реагирования.
> Введите номера ВСЕХ подтверждённых утверждений по возрастанию, без пробелов.

Первичная служебная записка

Подготовьте отчёт на 150–200 слов: подтверждённые факты, рабочая гипотеза, меры, открытые вопросы и следующие действия. У каждого существенного вывода укажите источник.

Все материалы этого учебного дела вымышлены.